

The background of the slide features a complex network diagram with numerous nodes and connecting lines, rendered in a light blue color against a dark blue background. The nodes are small squares, and the lines are thin and interconnected, creating a web-like structure that fills the entire slide.

Estrategias Avanzadas de **IAM y Federación de Identidad**

Sesión 5

Objetivos de la Sesión

1. Conceptos clave: Federación de identidad, SSO, SAML/OAuth.
2. Implementar federación en AWS (ej.: integración con Azure AD).
3. Configurar SSO empresarial con AWS IAM Identity Center.
4. Integrar Active Directory/LDAP con la nube.
5. Mitigar riesgos en sistemas federados.

¿Por qué es clave la Federación de Identidad?

Problemas que resuelve:

- Gestión de múltiples credenciales → **Reducción de fricción**.
- Cumplimiento normativo (GDPR, HIPAA).
- Seguridad mejorada: Menos contraseñas, más control.

Dato clave: *"La federación reduce en un 40% los costos de gestión de identidades"* (Gartner, 2022).

Conceptos Fundamentales

1. Federación de Identidad:

- Vincula sistemas locales (AD) con servicios en la nube.
- Protocolos: **SAML 2.0** (XML), **OAuth 2.0/OpenID Connect** (APIs).

2. Roles Federados:

- Asignación dinámica de permisos basada en identidad externa.

3. SSO (Inicio de sesión único):

- Una credencial → Acceso a múltiples servicios.
-

Flujo de Autenticación Federada (AWS/Azure AD)

Diagrama:

```
1 [Usuario] → Inicia sesión en Azure AD (IdP)
2 ↓
3 [Azure AD] → Genera aserción SAML
4 ↓
5 [AWS IAM] → Valida aserción y asigna rol temporal
6 ↓
7 [Usuario] → Accede a recursos de AWS (S3, EC2, etc.)
```

Herramientas: AWS IAM Identity Center, Azure AD Connect.

Implementación Práctica

– Federación SAML en AWS

Pasos:

1. Crear Proveedor de Identidad (IdP):

- En AWS IAM → Subir metadatos XML de Azure AD.

2. Crear Roles Federados:

- Ejemplo: Rol para el grupo "Finanzas". **S3ReadOnly**

3. Asignar permisos:

- Política IAM:

```
1 {  
2   "Version": "2012-10-17",  
3   "Statement": [{  
4     "Effect": "Allow",  
5     "Action": "s3:GetObject",  
6     "Resource": "*"   
7   }]  
8 }
```


Inicio de sesión único (SSO) con AWS IAM Identity Center

Configuración:

1. Habilitar IAM Identity Center en AWS.
2. Vincular con Azure AD (SAML/OIDC).
3. Asignar grupos de usuarios a roles AWS:
 - Ejemplo: Grupo "Desarrolladores" → . **Beneficio:** Reducción del 50% en boletos de soporte (Forrester, 2021). **EC2FullAccess**

Integración con Active Directory (AD)

Escenario:

• Empresa con AD local → Migración a AWS. **Pasos:**

1. Usar **AWS Directory Service** (Conector AD o Microsoft AD administrado).

2. Unir instancias EC2 al directorio:

```
1 sudo yum install -y sssd realmd
2 sudo realm join corp.example.com -U admin
```

3. Sincronizar usuarios y asignar roles IAM.

Seguridad en Sistemas Federados

Riesgos comunes:

- Roles con permisos excesivos (ej.:). `AdministratorAccess`
- IdP comprometido → Brecha masiva. Buenas prácticas:
- **MFA obligatorio** en IdP y AWS.
- **Principio de privilegio mínimo** en roles.
- Monitoreo con **AWS CloudTrail** (ej.: eventos). `AssumeRoleWithSAML`

Caso de Estudio

– Ataque de Federación

Escenario:

- Empresa financiera con federación AWS-Azure AD. **ataque:**
- Credenciales robadas → Intentos de acceso a roles críticos. **Mitigación:**

1. Habilitar MFA en Azure AD.

2. Reducir permisos de roles (ej.: vs.).

`s3:GetObject` | `s3:*`

3. Usar **AWS IAM Access Analyzer** para detectar configuraciones inseguras.

Errores Comunes y Soluciones

1. Permisos excesivos en roles federados:

- Solución: Usar el **Simulador de Políticas IAM**.

2. Certificados SAML vencidos:

- Solución: Renovar metadatos del IdP cada 6 meses.

3. Falta de MFA:

- Solución: Configurar políticas de acceso condicional en Azure AD.

Herramientas Clave

- **AWS:**

- Centro de identidad IAM, CloudTrail, Servicio de directorio.

- **Terceros:**

- Azure AD Connect, Auth0, Ping Identity.

- **Forense:**

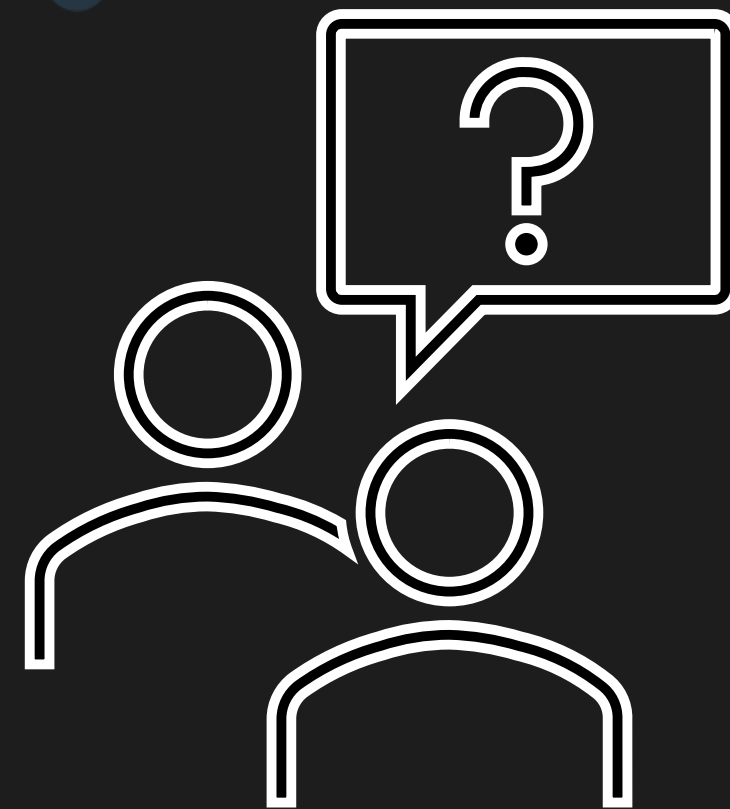
- AWS Athena + SIEM (Splunk) para análisis de registros..

Conclusión

- La federación de identidad es esencial para entornos híbridos.
- SSO + MFA + Monitoreo = Seguridad robusta.

Preguntas

- ¿Cómo mitigar riesgos de tokens SAML interceptados?
- ¿Qué alternativas existen a SAML para aplicaciones móviles?





Estrategias Avanzadas de **IAM y Federación de Identidad**